

LIVRABLE 1 — RAPPORT DE GESTION DE PROJET

Déploiement d'une Infrastructure de Cybersécurité Open Source pour PME

Projet OSSI

Résumé

Le projet OSSI (Open Source Security Infrastructure) répond à un problème actuel et réelle : les PME sont aujourd'hui la cible des cyberattaques, mais sont incapables de financer les solutions propriétaires de protection. Face à cette barrière économique, le projet propose de déployer une infrastructure de sécurité réseau complète et évolutive, reposant exclusivement sur des logiciels Open Source.

La solution sera un pare-feu central pfSense, des tunnels VPN chiffrés (IPSec inter-sites et WireGuard pour le télétravail), une sonde de détection et de prévention d'intrusions Suricata, un outil de métrologie ntopng et un modèle d'intelligence artificielle intégré (Ollama) générant des rapports de synthèse concis et accessibles au dirigeant non technicien.

Introduction

Dans le cadre du Mastercamp EFREI (module FG601), notre groupe a choisi de concevoir, planifier et piloter un projet dans le thème de la cybersécurité et de la protection des données. Ce thème s'impose comme l'un des enjeux technologiques et organisationnels important pour les prochaines décennies : selon l'ANSSI, les PME représentent aujourd'hui plus de 60 % des cibles d'attaques par rançongiciels en France, alors même qu'elles disposent structurellement de moins de ressources humaines et financières pour se protéger.

L'accélération du télétravail et des systèmes d'information ont élargi la surface d'attaque de ces structures, rendant indispensable la mise en place d'une infrastructure de sécurité numérique. C'est dans ce contexte que s'inscrit le projet OSSI.

Choix du projet :

Le projet OSSI répond à un paradoxe économique bien documenté : les PME sont les plus exposées aux cybermenaces, mais les solutions propriétaires de protection imposent un modèle économique de licences récurrentes et de dépendance fournisseur qui dépassent leur budget. Ce que le projet propose : changer ces coûts de licence par de l'expertise humaine en ingénierie open source.

Ce choix est pertinent pour une école d'ingénieurs car il mobilise simultanément des compétences en architecture réseau, en administration système, en cryptographie appliquée, en gestion de projet et en vulgarisation technique.

1.3 Pertinence du projet

Dimension	
Économique	Réduction du coût total de possession
Technologique	Mise en œuvre de technologies libres (pfSense, WireGuard, Suricata) et d'IA souveraine (Ollama)
Organisationnelle	Structuration en cycle en V, gouvernance claire, matrice RACI et plan de communication
Sociale	Démocratisation de la cybersécurité pour des structures qui en ont le plus besoin mais les moindres moyens

Partie I — Définition du Projet et Analyse du Besoin (MOA)

Responsable : Guillaume — Focus Cadrage & Valeur Métier

Part I: Rédaction Stratégique & Alignement Métier

1. Contexte du marché des PME face à la Cybersécurité

Aujourd'hui, les Petites et Moyennes Entreprises (PME) constituent le cœur de l'économie, mais elles sont devenues la cible privilégiée des cyberattaques. Moins protégées que les grands groupes, elles font face à une professionnalisation de la cybercriminalité (rançongiciels, vol de données, phishing). L'accélération du télétravail et l'interconnexion des systèmes d'information ont multiplié la surface d'attaque de ces structures, rendant indispensable la mise en place d'une infrastructure de sécurité périmétrique robuste.

2. Problématique des coûts des solutions propriétaires

La protection d'un réseau d'entreprise repose traditionnellement sur des solutions propriétaires (pare-feu de type Next-Gen de constructeurs leaders du marché). Cependant, ces solutions imposent un modèle économique lourd et inadapté aux budgets des PME :

- **Coûts d'acquisition initiaux élevés** pour le matériel informatique dédié.
- **Abonnements récurrents et licences d'exploitation** (licences par utilisateur, abonnements annuels pour les signatures d'intrusions ou le support).
- **Dépendance technologique (Vendor Lock-in)** empêchant la flexibilité et forçant au renouvellement du matériel à moyen terme.

Face à cette barrière financière, l'alternative open source se positionne comme une réponse pragmatique, permettant de transférer le budget des licences logicielles vers la valorisation de l'expertise humaine et l'optimisation des ressources existantes.

3. Définition des Objectifs SMART du Projet

Afin d'encadrer la réussite du projet OSSI (Open Source Security Infrastructure), les objectifs ont été définis selon la méthodologie SMART :

- **Spécifique (S)** : Déployer et durcir une infrastructure de sécurité réseau open source articulée autour d'un pare-feu pfSense, de tunnels VPN (IPSec et WireGuard), d'une sonde de détection d'intrusions (Suricata), d'un outil de métrologie (ntopng) et d'un modèle d'IA souverain local (Ollama).
- **Mesurable (M)** : L'infrastructure devra valider 100% des critères du plan de test (chiffrement effectif des tunnels, blocage et remontée d'alertes Suricata lors d'injections de paquets, et maintien des performances réseau validé par iPerf3).
- **Atteignable (A)** : Le périmètre est maîtrisé par une équipe projet de 5 ingénieurs spécialisés, s'appuyant sur des technologies open source matures et une démarche prédictive en Cycle en V.
- **Réaliste (R)** : La solution répond au besoin concret d'une PME de se protéger à moindre coût matériel en tirant parti du "coût gratuit" du logiciel libre pour investir sur l'administration système.
- **Temporellement défini (T)** : Le projet est strictement limité à la temporalité de la simulation Mastercamp, soit une planification ordonnancée sur 8 séances, avec un gel de la configuration en séance 7 et une clôture définitive en séance 8.

Part II: Outils Méthodologiques

1. La Fiche Projet (Project Charter)

PROJECT CHARTER — PROJET OSSI

Nom du Projet : Open Source Security Infrastructure (OSSI)

Sponsor du Projet : Dr. Haraké

Chef de Projet : Kevin (Focus Planification & Jalons)

Date de Lancement : Séance 01 | **Date de Clôture :** Fin de Séance 08

1. Justification & Alignement Métier > Permettre aux PME d'accéder à un niveau de sécurité périmétrique d'ordre industriel sans subir la barrière financière des licences propriétaires, en exploitant la flexibilité et la gratuité des briques logicielles open source.

2. Description du Périmètre (Livrables clés) >

- * Passerelle de sécurité durcie (pfSense) avec segmentation réseau et services DNS chiffrés.
- * Tunnel IPSec permanent (inter-sites) et accès VPN à double facteur pour le télétravail.
- * Sonde cyber active (Suricata/ntopng) couplée à un modèle d'IA local (Ollama) pour la vulgarisation des alertes.

3. Contraintes & Facteurs Critiques de Succès >

- * **Temporelle** : Livraisons et soutenances calées sur le calendrier non négociable du Mastercamp.
- * **Technique** : Stabilité requise des interconnexions de briques libres hétérogènes.
- * **Qualité** : Obligation d'une traçabilité totale entre les exigences initiales et les rapports de test iPerf3.

4. Équipe Projet & Responsabilités macroscopiques >

- * **Kevin (CP)** : Planification, WBS, Gantt et Chemin critique.
- * **Guillaume (MOA)** : Cadrage, alignement métier, arbitrage MoSCoW.
- * **Mohamed (MOE)** : Architecture technique, déploiement et interopérabilité.
- * **Antoine (RBQ)** : Gestion des risques, budgets, tests de charge et cellule de crise.
- * **Emmanuel (GCD)** : Gouvernance humaine, RACI, communication et centralisation qualité.

2. L'analyse "Projet vs Opération"

Il est crucial pour la gouvernance de la PME de comprendre la frontière entre la phase temporaire du projet et la vie courante (opérationnelle) de l'infrastructure délivrée.

- **La Phase Projet (Temporaire & Unique)** : Le projet OSSI est par définition une impulsion temporaire visant à créer un produit unique. Il commence à la séance 1 et s'arrête à la séance 8. Durant cette phase, l'équipe consomme un budget d'ingénierie (108 heures de charge cumulées) pour concevoir l'architecture, installer l'OS pfSense, configurer les tunnels VPN et la sonde Suricata, et enfin valider la stabilité du système par des recettes techniques. Une fois le transfert de propriété effectué en séance 8, le projet meurt pour laisser place aux opérations.

- **La Phase Opérationnelle (Permanente & Répétitive) :** L'infrastructure entre ensuite dans son cycle de vie d'exploitation courante au sein de la PME. Les opérations n'ont pas de date de fin prédéfinie et visent à maintenir le niveau de sécurité atteint. Elles incluent :
 - **La maintenance récurrente de pfSense :** Application des correctifs de sécurité OS, sauvegardes régulières des fichiers de configuration, et gestion des accès (création/révocation des certificats des télétravailleurs).
 - **La mise à jour des règles Suricata :** Téléchargement périodique des bases de signatures de menaces (ex: règles Emerging Threats) pour maintenir l'efficacité de la sonde face aux vulnérabilités 0-day.
 - **La supervision au quotidien :** Analyse des flux via ntopng et exploitation des rapports vulgarisés de l'IA locale pour piloter la politique de sécurité.

3. La Matrice MoSCoW Dédiée

Cette matrice formalise les arbitrages fonctionnels du projet. Elle permet de garantir au Comité de Pilotage que le cœur sécuritaire de l'infrastructure sera livré en priorité en cas de fortes tensions sur le chemin critique.

Catégorie	Fonctionnalités & Éléments du Système	Justification Métier / Impact sur le Projet
Must have (Obligatoire)	- Déploiement du pare-feu central pfSense - Configuration du Tunnel VPN IPSec (Inter-sites) - Intégration de la Sonde IDS/IPS Suricata	Cœur de la sécurité périmétrique : Sans ces composants, l'infrastructure n'offre aucun cloisonnement, aucune connectivité sécurisée pour les filiales et aucune détection face aux intrusions.
Should have (Important)	- Règles de Traffic Shaping (Priorisation des flux) - Collecte et centralisation des Logs (ntopng)	Optimisation et Visibilité : Essentiel pour garantir la bande passante des applications métiers face aux usages récréatifs et identifier l'origine d'un comportement suspect sur le réseau.
Could have (Confort)	- Modèle d'IA local souverain (Ollama)	Plus-value et Vulgarisation : Permet au dirigeant de la PME de comprendre l'état de sa sécurité sans compétences

	- Génération automatique du Rapport de sécurité "No-Expert"	techniques avancées, mais son absence ne compromet pas le filtrage ou le chiffrement du réseau.
Won't have (Exclu pour ce livrable)	- Déploiement d'un SIEM lourd classique (ex: ELK complet) - Dashboard centralisé multi-tenant externe	Hors-périmètre et restrictions de ressources : Trop gourmand en ressources matérielles (coûts cachés d'infrastructure) pour une infrastructure PME standard lors de ce premier jalon.

Partie II — Gouvernance, Parties Prenantes et Synergie (GCD)

Responsable : Membre 5 — Focus Humain, Gouvernance & Documentation

1. Organisation de l'équipe projet

L'équipe projet est composée de 5 membres, chacun titulaire d'un rôle clairement défini en cohérence avec les responsabilités exigées par le TD 01. Le mode d'organisation retenu est matriciel léger : chaque membre dispose d'une spécialité fonctionnelle et rend compte au chef de projet pour les arbitrages transverses.

2. Analyse des parties prenantes

2.1 Parties prenantes internes

Partie prenante	Rôle	Attentes principales
Dr. Haraké (Sponsor)	Commanditaire fictif et évaluateur pédagogique	Rigueur méthodologique, respect du cadre TD 01, qualité académique du livrable
Kevin (CP)	Chef de projet	Respect du planning, cohérence du Gantt, coordination des jalons
Guillaume (MOA)	Responsable cadrage	Alignement métier, objectifs SMART, matrice MoSCoW validée
Mohamed (MOE)	Responsable architecture	Stabilité technique, interopérabilité des composants open source
Antoine (RBQ)	Risques, Budget, Qualité	Maîtrise des coûts, registre des risques à jour, critères qualité atteints
Emmanuel (GCD)	Gouvernance & Documentation	Cohérence du rapport, plan de communication respecté, RACI clair

2.2 Parties prenantes externes

Partie prenante	Intérêt	Influence
PME utilisatrices	Bénéficiaires directs de l'infrastructure déployée	Forte (critères d'acceptation du livrable)
Administrateur IT PME	Exploitant quotidien de la solution après transfert	Modérée (retours sur la maintenabilité)
Communauté open source	Fournisseur implicite des briques logicielles	Indirecte (qualité des outils, mises à jour)
Régulateurs (ANSSI, CNIL)	Conformité réglementaire RGPD et recommandations NIS2	Modérée (cadre normatif)

3. Cartographie Pouvoir / Intérêt

	Faible intérêt	Fort intérêt
Fort pouvoir	Régulateurs (ANSSI, CNIL)	Sponsor / Comité de pilotage (Dr. Haraké)
Faible pouvoir	Communauté open source	PME utilisatrices Administrateur IT Équipe projet

4. Matrice RACI

Tâche / Livrable	CP (Kevin)	MOA (Guillaume)	MOE (Mohamed)	RBQ (Antoine)	GCD (Emmanuel)
Charte projet & objectifs SMART	A	R	C	I	I
Architecture réseau sécurisée	A	I	R	C	I
WBS & Dictionnaire des tâches	R	C	C	C	A
Diagramme de Gantt	R	I	I	I	A
Registre des risques	A	C	C	R	I
Budget prévisionnel	A	I	I	R	I
Déploiement pfSense / VPN	A	I	R	C	I
Tests & Recette technique (iPerf3)	A	I	C	R	I
Plan de communication	A	I	I	I	R
Centralisation & rapport final	A	I	I	I	R

R = Responsable (réalise) | A = Accountable (valide) | C = Consulted (consulté) | I = Informed (informé)

Partie III — Structuration et Planification du Projet (CP)

Partie I : Cadrage Méthodologique – Le Choix du Cycle en V

Pour mener à bien le déploiement de notre infrastructure de sécurité open source dédiée aux PME, le choix d'une méthodologie de gestion de projet rigoureuse est une condition indispensable de réussite. Dans le cadre d'un projet de cybersécurité, l'équipe a délibérément exclu une approche purement agile. Bien que l'Agilité soit performante pour le développement logiciel, elle s'avère trop instable pour la mise en place d'architectures réseau critiques. Une modification impromptue ou une itération mal maîtrisée sur un pare-feu central peut instantanément paralyser l'ensemble des flux de l'entreprise ou ouvrir des brèches de sécurité majeures. C'est pourquoi, en tant que Maîtrise d'Œuvre, nous avons choisi de nous appuyer sur la rigueur du **Cycle en V**, une approche prédictive qui garantit une traçabilité absolue entre les besoins exprimés par le client et les tests de validation finaux.

La phase descendante de notre cycle commence par l'analyse approfondie des exigences des PME, notamment la réduction drastique des coûts de licence et la simplification de la gestion de la sécurité. Ces besoins macroscopiques sont ensuite traduits en spécifications fonctionnelles, puis en une architecture technique détaillée qui formalise l'interopérabilité entre pfSense, le VPN WireGuard et le système de détection d'intrusions Suricata. Cette approche structurée nous impose de figer l'adressage IP, la segmentation réseau et les mécanismes de chiffrement avant de démarrer la moindre configuration. Elle assure ainsi une base technique saine et élimine le risque de dérive des objectifs, un piège fréquent lorsque l'on manipule de multiples briques open source interconnectées.

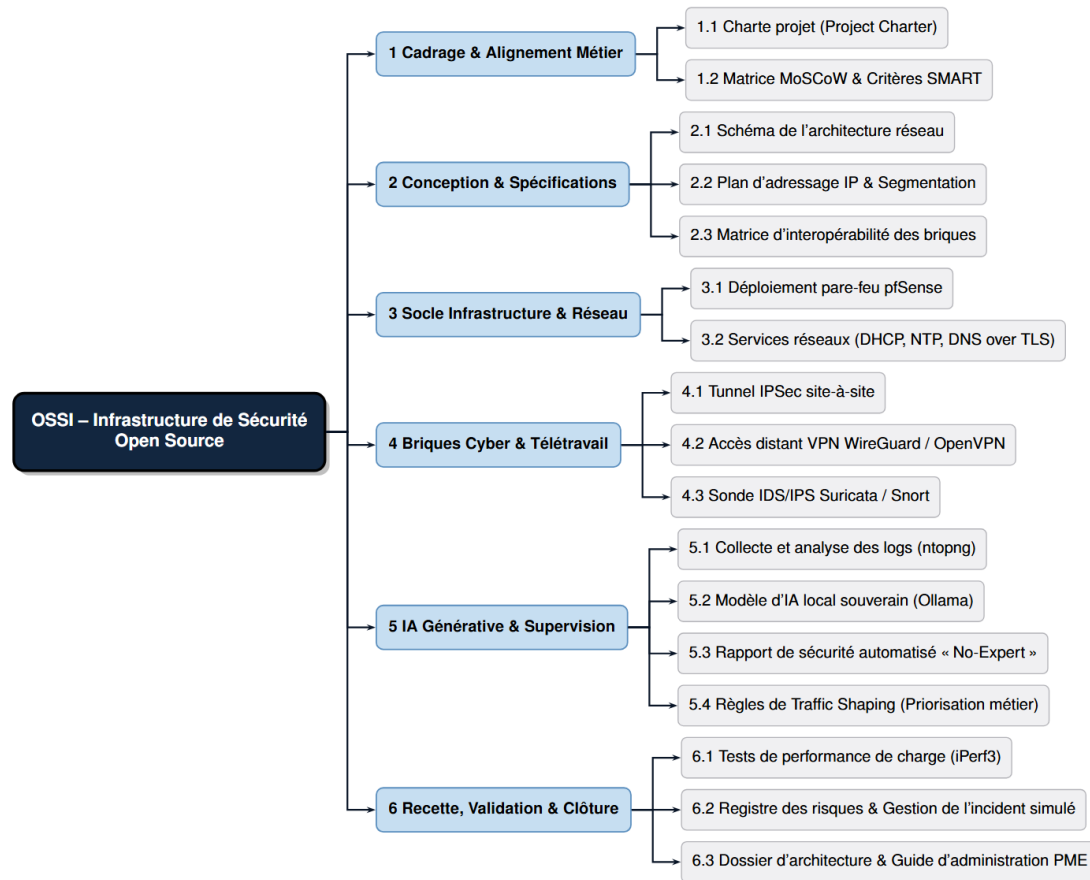
La force de cette méthodologie se révèle pleinement dans sa phase ascendante, où chaque niveau de conception trouve son pendant exact dans un plan de validation. Ainsi, l'implémentation concrète des services sur pfSense fera l'objet de tests unitaires, tandis que la synergie globale de l'infrastructure sera validée par des tests d'intégration et de performance robustes. Nous utiliserons notamment iPerf3 pour valider l'impact du trafic shaping et nous simulerons des injections de paquets suspects pour vérifier la réactivité des alertes de Suricata. Cette correspondance stricte permet de garantir au Comité de Pilotage que chaque exigence de l'appel d'offres initial est non seulement implémentée, mais scientifiquement vérifiée.

Enfin, le Cycle en V s'articule parfaitement avec la temporalité et les contraintes de la simulation Mastercamp. Il permet de découper notre projet en jalons non négociables et de structurer notre futur Organigramme Technique de Produit (WBS) en lots de travaux chronologiques clairs. Cette visibilité offre un cadre stable pour identifier notre chemin critique sur le diagramme de Gantt, et permettra au Responsable Risques d'anticiper efficacement l'impact de l'incident simulé sans compromettre les livraisons finales.

Partie 2 : L'Organigramme Technique de Produit (WBS)

L'Organigramme Technique de Produit (WBS — Work Breakdown Structure) constitue l'outil pivot de la structuration macroscopique du projet OSSI. Élaboré dans le respect strict de la « règle des 100 % », cet arbre hiérarchique capture l'intégralité du périmètre du projet sans aucune omission ni duplication. Sa trajectoire descendante s'aligne rigoureusement sur les phases de notre démarche en Cycle en V : il traduit les exigences conceptuelles en lots de travail concrets (Niveau 1), puis en unités de livrables physiques, logicielles ou documentaires vérifiables (Niveau 2). En se focalisant exclusivement sur les résultats attendus plutôt que sur les actions, ce WBS sécurise le périmètre de l'infrastructure open source et pose les fondations indispensables à l'établissement de la matrice des responsabilités (RACI) et de la planification temporelle (Gantt).

Organigramme Technique de Produit (WBS) — Projet OSSl



Partie 3 : Le Dictionnaire des Tâches (DDT)

Le dictionnaire des tâches constitue le prolongement opérationnel indispensable de notre WBS. Alors que l'organigramme technique se borne à lister et hiérarchiser les livrables, le dictionnaire les définit de manière univoque en fixant leurs frontières techniques. Pour chaque lot de travail (Work Package), il détermine avec précision les données d'entrée requises, la description fine des tâches à exécuter, le livrable attendu, la durée estimée et le responsable principal de l'exécution. Cet outil offre deux avantages majeurs pour notre équipe : il élimine toute ambiguïté sur le « qui fait quoi » (sécurisant la future matrice RACI) et quantifie la charge de travail en heures, ce qui fournit la matière première indispensable au Chef de Projet pour calculer le chemin critique du diagramme de Gantt.

N°	Lot / Work Package	Données d'Entrée	Description de l'Exécution	Livrable Attendu	Durée	Responsable Principal
1.1	Charte Projet	Sujet de l'appel d'offres et objectifs Mastercamp	Rédaction des objectifs SMART, des contraintes macroscopiques et du périmètre initial du projet	Document Project Charter validé	4 h	Responsable MOA
1.2	Matrice MoSCoW	Besoins recensés des PME	Classification et arbitrage des fonctionnalités cyber	Tableau de priorisation MoSCoW intégré au rapport	3 h	Responsable MOA

			indispensables et optionnelles			
2.1	Schéma d'Architecture	Besoins de connectivité entre le Site Principal et le Site Isolé	Modélisation graphique des flux, interconnexions de sécurité et briques logicielles open source	Diagramme d'architecture réseau sécurisé	6 h	Responsable MOE
2.2	Plan d'Adressage IP	Schéma d'architecture réseau validé	Définition des sous-réseaux (LAN, DMZ, VPN), masques et règles de segmentation des flux	Tableau d'adressage IP et matrice de routage	4 h	Responsable MOE
2.3	Matrice d'Interopérabilité	Documentations de pfSense, WireGuard et Suricata	Étude et validation technique de la bonne synergie des composants de l'infrastructure	Document de spécifications des interfaces d'échange	4 h	Responsable MOE
3.1	Déploiement pfSense	Matrice d'architecture et plan d'adressage IP	Installation de l'OS pfSense, configuration des interfaces WAN/LAN et durcissement du pare-feu	Instance pfSense opérationnelle et sécurisée	8 h	Responsable MOE
3.2	Services Réseaux	Serveurs pfSense déployés	Configuration et cloisonnement des services DHCP, NTP et activation du protocole DNS over TLS	Services réseaux actifs et flux DNS chiffrés	4 h	Responsable MOE
4.1	Tunnel IPSec Site-à-Site	Clés PKI et adresses IP des box (Fixe vs Dynamique)	Configuration du tunnel chiffré permanent entre le Site Principal et le Site Isolé	Liaison IPSec active et flux inter-sites sécurisés	8 h	Responsable MOE
4.2	Accès Distant VPN	Certificats d'authentification des télétravailleurs	Configuration des serveurs de terminaison WireGuard ou OpenVPN et intégration de la double authentification	Tunnels d'accès distants opérationnels avec 2FA	8 h	Responsable MOE
4.3	Sonde IDS/IPS	Cartographie des menaces et vulnérabilités	Installation de Suricata ou Snort, activation des cartes en mode promiscuité et paramétrage des règles	Système d'alerte et de blocage d'intrusions actif	10 h	Responsable RBQ

5.1	Collecte de Logs	Interfaces réseau pfSense et Suricata	Intégration de l'outil ntopng pour capturer, analyser et journaliser l'activité du trafic réseau	Flux de journalisation centralisés et visibles	6 h	Responsable MOE
5.2	Modèle d'IA Local	Flux de logs générés par ntopng et Suricata	Déploiement du modèle Ollama en local et écriture du script d'interfaçage avec les alertes cyber	Instance IA opérationnelle et connectée aux logs	12 h	Responsable MOE
5.3	Rapport No-Expert	Sorties brutes du modèle d'IA local	Développement du gabarit de synthèse automatique traduisant le jargon cyber en langage business	Interface ou modèle de rapport vulgarisé fonctionnel	6 h	Responsable GCD
5.4	Traffic Shaping	Liste des applications métiers prioritaires de la PME	Configuration des files d'attente pfSense pour brider le streaming au profit des flux critiques	Politique de QoS active et bande passante optimisée	6 h	Responsable RBQ
6.1	Tests de Performance	Infrastructure globale déployée	Exécution de campagnes de charge réseau via iPerf3 pour valider la robustesse du système	Rapport de recette technique et de bande passante	6 h	Responsable RBQ
6.2	Gestion des Risques	Registre initial des menaces et survenance de l'incident	Simulation de l'incident majeur, analyse d'impact QCD et mise en œuvre des contre-mesures	Registre mis à jour et plan de continuité d'activité	5 h	Responsable RBQ
6.3	Dossier de Clôture	Fichiers de configuration, scripts et captures de tests	Consolidation de la documentation d'architecture technique et rédaction du guide utilisateur PME	Manuel d'administration et rapport final validés	8 h	Responsable GCD

Partie 4 : Planification Temporelle et Ordonnancement

1. Introduction et Logique d'Ordonnancement (Gantt)

La planification temporelle du projet OSSI (Open Source Security Infrastructure) traduit la charge de travail macroscopique issue du dictionnaire des tâches en un calendrier d'exécution linéaire. Réparti sur les 8 séances de la simulation Mastercamp, l'ordonnancement de nos lots de travail a été structuré pour répondre à deux impératifs majeurs du management de projet : le respect rigoureux des dépendances techniques et le lissage de la charge de travail au sein de notre équipe de 5 ingénieurs. S'inscrivant dans la logique séquentielle de notre cycle de vie en Cycle en V, la planification sépare distinctement la phase de spécification (Séance 1), la phase d'implémentation et de durcissement (Séances 2 à 6), et enfin la phase de recette et de clôture (Séances 7 et 8). Cette approche garantit

qu'aucune configuration technique n'est démarrée sans une validation théorique préalable, limitant ainsi drastiquement les risques de non-qualité ou de refonte en cours de route.

2. Découpage et Chronologie des Activités par Séance

Afin d'assurer un suivi rigoureux, les 108 heures de charge globale estimées ont été réparties selon le calendrier opérationnel suivant :

- **Séance 01 — Cadrage & Spécifications Initiales** : Cette première session est dédiée à l'alignement métier et au verrouillage du périmètre. L'équipe formalise la Charte Projet (1.1) et la Matrice MoSCoW (1.2). En parallèle, la maîtrise d'œuvre (MOE) entame immédiatement la conception théorique : l'élaboration du Schéma d'Architecture (2.1), du Plan d'Adressage IP (2.2) et de la Matrice d'Interopérabilité (2.3).
- **Séance 02 — Validation et Lancement du Socle Infrastructure** : Le début de la séance est marqué par le premier jalon majeur du projet (la soutenance orale du Livrable 2). Dès l'obtention du feu vert du Comité de Pilotage, la phase de construction démarre par le déploiement et le durcissement du pare-feu central pfSense (3.1).
- **Séance 03 — Finalisation des Réseaux & Rendu** : Cette séance coïncide avec le gel et la livraison du Rapport écrit (Livrable 1). Sur le plan technique, l'équipe finalise les Services Réseaux essentiels (3.2) comme le DHCP et le DNS over TLS, et initialise la connectivité inter-sites via le premier tunnel IPsec permanent (4.1).
- **Séance 04 & 05 — Implémentation Cyber & Télétravail** : Phase intensive du projet. La MOE configure l'infrastructure d'accès distant sécurisé WireGuard/OpenVPN avec authentification double facteur (4.2). En parallèle, le Responsable Risques et Qualité déploie la sonde de détection d'intrusions Suricata (4.3). En fin de Séance 5, la collecte et la centralisation des logs via l'outil ntopng (5.1) sont activées.
- **Séance 06 — Intelligence Artificielle & Optimisation des Flux** : Une fois les données de trafic stabilisées, le modèle d'IA local Ollama (5.2) est déployé. Le Responsable Gouvernance (GCD) conçoit l'interfaçage pour générer automatiquement le Rapport No-Expert (5.3), tandis que la cellule technique applique les règles de Traffic Shaping (5.4) pour prioriser la bande passante des applications métiers.
- **Séance 07 — Recette Technique & Gestion de l'Incident Simulé** : L'infrastructure étant pleinement opérationnelle, l'équipe exécute des tests de charge via iPerf3 (6.1). C'est lors de cette séance que survient l'incident cyber simulé (6.2). L'équipe active sa cellule de crise pour analyser l'impact sur le triangle QCD et implémenter les contre-mesures.
- **Séance 08 — Clôture & Transfert de Propriété** : Phase de capitalisation. L'équipe consolide l'ensemble des fichiers de configuration et rédige le Guide d'Administration PME (6.3) pour finaliser le Dossier de Clôture.

3. Analyse du Chemin Critique (Critical Path)

Le chemin critique représente la suite séquentielle de tâches interdépendantes qui détermine la durée minimale incompressible du projet. Tout retard sur l'une de ces activités impactera de manière directe et géométrique la date de livraison finale de l'infrastructure.

Pour le projet OSSI, le chemin critique est purement technique et s'établit comme suit :

2.1 (Schéma d'Architecture) → 3.1 (Déploiement pfSense) → 4.1 (Tunnel IPsec) → 4.3 (Sonde Suricata) → 5.2 (Modèle IA Local) → 6.1 (Tests iPerf3) → 6.3 (Dossier de Clôture)

4. Jalons Clés du Projet (Milestones)

Les jalons sont des événements de durée nulle matérialisant des points de contrôle décisionnels ou des livraisons incontournables :

- **T0 (Début Séance 01)** : Lancement officiel du projet OSSI et ouverture des chantiers.
- **Jalon 1 (Milieu Séance 02)** : Soutenance orale devant le Comité de Pilotage (Livrable 2).
- **Jalon 2 (Début Séance 03)** : Rendu officiel du Rapport écrit de cadrage (Livrable 1).
- **Jalon 3 (Fin Séance 07)** : Résolution validée de l'incident simulé et gel de la configuration technique.
- **Jalon 4 (Fin Séance 08)** : Livraison du Dossier d'Architecture Technique et transfert des clés à la PME — Clôture du Projet.

PROJET OSSI – DIAGRAMME DE GANTT | Infrastructure de Sécurité Open Source

| Tâche normale | Chemin Critique

Code WBS	Livrable / Tâche	Séance Début	Séance Fin	Prédécesseurs	S1	S2	S3	S4	S5	S6	S7	S8
1,1	Charte Projet	1	1	Aucune								
1,2	Matrice MoSCoW	1	1	1,1								
2,1	Schéma d'Architecture	1	1	1,1								
2,2	Plan d'Adressage IP	1	2	2,1								
2,3	Matrice d'Interopérabilité	1	2	2,1								
3,1	Déploiement pfSense	2	2	Jalon 1								
3,2	Services Réseaux	2	3	3,1								
4,1	Tunnel IPSec Site-à-Site	3	3	3.1, 2.2								
4,2	Accès Distant VPN	4	4	3.1, 2.2								
4,3	Sonde IDS/IPS Suricata	4	5	3,1								
5,1	Collecte de Logs (ntopng)	5	5	4,3								
5,2	Modèle d'IA Local (Ollama)	6	6	5,1								
5,3	Rapport No-Expert	6	6	5,2								
5,4	Traffic Shaping	6	7	3,1								
6,1	Tests de Performance (iPerf3)	7	7	4.1, 4.2, 5.4								
6,2	Gestion de l'Incident Simulé	7	7	Incident								
6,3	Dossier de Clôture & Guides	8	8	6.1, 6.2								

? Chemin Critique : 2.1 ? 3.1 ? 4.1 ? 4.3 ? 5.2 ? 6.1 ? 6.3 | Durée totale du projet : 8 séances

Partie IV — Ingénierie Financière, Qualité et Gestion des Risques (RBQ)

Responsable : Antoine Poirier — Risques, Budget & Qualité

1. Analyse économique — Le coût réel de l'open source

L'argument central du projet repose sur l'usage de logiciels open source, sans coût de licence. Cet avantage est réel mais ne constitue pas une gratuité totale. En gestion de projet, on raisonne en coût complet de possession : un outil libre déplace le coût de la licence vers le temps humain nécessaire pour l'installer, le configurer, l'interpréter et le maintenir. C'est ce coût caché qui freine aujourd'hui l'adoption de telles solutions par les PME, et que le projet OSSSI cherche à réduire.

Une infrastructure open source non accompagnée génère plusieurs coûts invisibles. Le premier est le temps d'administration : paramétrage de pfSense, écriture des règles Suricata, gestion des certificats de la PKI et lecture quotidienne des journaux et des graphiques produits par ntopng. Le deuxième est la montée en compétence de l'administrateur, sur des outils que la PME ne maîtrise pas en interne. Le troisième est le coût matériel et énergétique : même du matériel reconditionné a un prix d'achat, de remplacement et de consommation électrique, l'infrastructure fonctionnant en continu.

À titre de comparaison, une solution propriétaire de type pare-feu nouvelle génération impose un coût d'acquisition matériel élevé, des abonnements annuels pour les signatures et le support, ainsi qu'une dépendance au fournisseur. Sur trois ans, le coût total dépasse fréquemment 45 000 euros pour une PME, ou impose le recrutement d'un profil technique dédié. La solution OSSSI repose à l'inverse sur un investissement matériel modeste, du matériel de récupération ou reconditionné, et un coût d'exploitation annuel de l'ordre de 1 500 à 2 000 euros une fois l'infrastructure stabilisée. Sur trois ans, son coût complet se situe autour de 8 000 euros. L'économie provient du transfert du budget des licences vers l'administration système, complétée par la synthèse automatique des alertes qui réduit le temps d'interprétation à la charge de la PME.

2. Critères de qualité de l'infrastructure

La qualité de l'infrastructure se mesure à partir de critères chiffrés, qui servent également de critères d'acceptation : un livrable n'est validé que lorsque sa cible est atteinte. Ils s'articulent avec le plan de validation du Cycle en V défini par la maîtrise d'œuvre.

La disponibilité de la passerelle et des tunnels VPN doit atteindre au moins 99,5 %, soit un temps d'interruption inférieur à trois heures et demie par mois. La performance réseau est vérifiée par les campagnes iPerf3 : le débit utile doit rester proche du débit nominal du lien et les applications métiers doivent demeurer prioritaires sous charge grâce au trafic shaping. L'efficacité de la détection est évaluée par injection de paquets de test, avec un taux de détection élevé et un taux de faux positifs maintenu sous le seuil fixé. La confidentialité est assurée par le traitement local des données, sans envoi vers des serveurs externes. La maintenabilité se traduit par un temps de remise en service court après incident, rendu possible par les sauvegardes de configuration. Enfin, le durcissement de pfSense doit respecter l'ensemble des règles de configuration jugées critiques. Ces seuils alimentent le tableau de bord de pilotage du projet.

3. Budget prévisionnel

Le budget valorise deux ressources : le temps d'ingénierie de l'équipe (108 heures issue du dictionnaire des tâches, valorisées à 50 €/h — profil junior cybersécurité) et le matériel reconditionné.

Poste	Charge (h)	Coût (€)
-------	------------	----------

Lot 1 — Cadrage et spécifications (1.1, 1.2)	7	350
Lot 2 — Conception et architecture (2.1 à 2.3)	14	700
Lot 3 — Socle pfSense et services réseau (3.1, 3.2)	12	600
Lot 4 — Tunnels VPN et sonde de détection (4.1 à 4.3)	26	1 300
Lot 5 — Supervision, IA locale et QoS (5.1 à 5.4)	30	1 500
Lot 6 — Recette, risques et clôture (6.1 à 6.3)	19	950
Sous-total ressources humaines	108	5 400
Matériel reconditionné (pfSense box, serveur, switch, câblage)	—	850
Marge de sécurité (10 %)	—	625
TOTAL PROJET (estimatif)	—	6 875

4. Triangle Coût – Délai – Qualité et arbitrages

Le projet est encadré par trois variables interdépendantes. Le délai constitue une contrainte ferme : la planification est calée sur les 8 séances du Mastercamp, sans report possible. La qualité du socle de sécurité est tout aussi prioritaire, car une infrastructure de protection peu fiable n'a aucune valeur pour la PME. La variable d'ajustement est donc le périmètre, en cohérence avec la matrice MoSCoW.

Scénario de pression	Variable ajustée	Arbitrage retenu
Réduction du délai	Qualité fragilisée (recette écourtée)	Inacceptable — qualité sécurité non négociable
Réduction du budget matériel	Capacités de supervision limitées	Acceptable via matériel reconditionné (déjà intégré)
Exigences qualité accrues	Charge et besoins matériels augmentés	Absorption par la marge de sécurité (10 %)
Tension sur le chemin critique	Périmètre réduit (fonctions confort reportées)	Report de l'IA Ollama en priorité — Must Have protégés

5. Registre des Risques

Chaque risque est coté selon sa probabilité (P) et son impact (I) sur une échelle de 1 à 4. La criticité = $P \times I$. Seuils : Faible (1–3), Modérée (4–8), Élevée (9–16).

Risque	Catégorie	P	I	Criticité	Responsable	Mesure préventive	Mesure corrective
Retard sur le chemin critique	Planning	3	3	9 — Élevée	CP	Suivi hebdomadaire des jalons	Réaffectation charge, report fonctions confort
Indisponibilité d'un membre clé	Humain	2	3	6 — Modérée	CP	Binôme et documentation partagée	Redistribution des tâches
Mauvaise config PKI (certificats VPN)	Technique/Cyber	3	4	12 — Élevée	RBQ	Procédure documentée, relecture croisée	Régénération autorité et certificats

Effondrement tunnel IPSec post-MAJ	Technique	3	3	9 — Élevée	MOE	Sauvegarde avant MAJ, test pré-production	Restauration config, bascule WireGuard
Faillle 0-day sur pfSense	Cyber	2	4	8 — Modérée	MOE	Veille vulnérabilités, segmentation réseau	Isolement service, règle Suricata, correctif
Faux positifs Suricata	Qualité	3	2	6 — Modérée	MOE	Réglage progressif, liste blanche	Recalibrage des règles de détection
Dérive périmètre vers SIEM	Organisationnel	2	2	4 — Modérée	MOA	Périmètre figé par matrice MoSCoW	Arbitrage comité de pilotage
Dépassement budget matériel	Financier	2	2	4 — Modérée	RBQ	Matériel reconditionné, marge 10 %	Repli sur composants moins coûteux
Non-appropriation par l'admin PME	Parties prenantes	2	3	6 — Modérée	GCD	Documentation accessible, accompagnement	Formation complémentaire, rapports simplifiés

6. Indicateurs de Pilotage

Dimension	Indicateur	Cible / Seuil d'alerte
Avancement	% tâches WBS complétées / planifiées	≥ 90 % à chaque jalon
Respect des délais	Nombre de tâches critiques en retard	0 — alerte si > 2 h de dérive
Budget	Charge consommée vs planifiée	< 10 % de dépassement (couvert par marge)
Qualité	% critères d'acceptation validés	100 % en phase de recette
Risques	Nombre de risques élevés actifs	≤ 2 — au-delà, réunion de crise
Satisfaction parties prenantes	Retours comité de pilotage (jalons)	Avis favorable à chaque soutenance
Conformité livrables	Écarts vs dictionnaire des tâches	0 livrable manquant à la clôture

Partie V — Spécifications Cyber-Architecture et Plan de Validation (MOE)

Responsable : Mohamed — Architecture & Technique

1. Description de la solution technique

L'architecture proposée repose sur pfSense comme brique centrale, sur laquelle s'appuient l'ensemble des composants de sécurité. Chacun des trois sites de l'entreprise dispose de sa propre instance pfSense gérant le pare-feu, le routage, le VPN, le DNS et le DHCP. Cette approche centralisée par site garantit une cohérence de configuration tout en limitant le nombre d'outils à administrer par une équipe IT réduite.

1.1 Composants retenus

Composant	Outil retenu	Rôle
Pare-feu / Routage	pfSense	Filtrage, NAT, segmentation réseau
VPN site-à-site	IPSec (via pfSense)	Tunnel chiffré permanent entre les sites
VPN accès distant	WireGuard (via pfSense)	Connexion sécurisée des télétravailleurs
IDS / IPS	Suricata	Détection et prévention d'intrusions
Analyse du trafic	ntopng	Supervision et traffic shaping
PKI	Easy-RSA (via pfSense)	Gestion des certificats internes
DNS sécurisé	DNS over TLS (via pfSense)	Chiffrement des requêtes DNS

1.2 Segmentation réseau par site

Zone	Rôle	Exemple
WAN	Connexion Internet et tunnels VPN	Lien ISP, IPSec, WireGuard
LAN	Réseau interne des employés	Postes de travail, imprimantes
DMZ	Services exposés éventuels	Serveur web, accès distant
Management	Administration des équipements	Interface pfSense, ntopng

1.3 Plan d'adressage

Site	Plage IP LAN
Site 1 (Principal)	192.168.1.0/24
Site 2	192.168.2.0/24
Site 3 (Isolé)	192.168.3.0/24

2. Justification des choix techniques

Comparatif	Solution retenue	Alternative écartée	Raison du choix
Pare-feu	pfSense	OPNsense	Meilleure intégration native Suricata, WireGuard, PKI ; communauté plus large

VPN accès distant	WireGuard	OpenVPN	Code plus léger, performances supérieures, chiffrement moderne, intégration native pfSense
IDS/IPS	Suricata	Snort	Multi-thread, règles Emerging Threats auto-mises à jour, modes IDS et IPS natifs
Analyse trafic	ntopng	Solutions généralistes	Analyse fine du trafic en temps réel et traffic shaping sans modules complémentaires

3. Contraintes techniques

3.1 Contraintes matérielles (par site)

Ressource	Minimum requis	Recommandé
Processeur	2 cœurs	4 cœurs
Mémoire RAM	4 Go	8 Go
Stockage	20 Go SSD	50 Go SSD
Interfaces réseau	2 (WAN + LAN)	3 (WAN + LAN + DMZ)
Connexion Internet	10 Mbps symétrique	50 Mbps symétrique

3.2 Contraintes réseau et logicielles

- Les plages d'adressage IP des différents sites ne doivent pas se chevaucher.
- Les adresses IP publiques (WAN) doivent être fixes ou s'appuyer sur un service de DNS dynamique.
- Ports UDP 500 et 4500 ouverts pour IPSec ; port UDP 51820 pour WireGuard.
- pfSense version 2.7 minimum (support natif WireGuard).
- Suricata nécessite au minimum 2 Go de RAM dédiés pour fonctionner stablement.
- La PKI (Easy-RSA) doit être opérationnelle avant tout déploiement VPN.

4. Ordre de déploiement et dépendances

Le déploiement suit une logique de dépendances strictes : chaque composant repose sur la disponibilité du précédent. La PKI doit être en place avant la configuration de tout VPN, et pfSense doit être pleinement opérationnel avant l'intégration de Suricata, ntopng ou du DNS over TLS.

Étape	Composant	Durée estimée
1	pfSense sur l'ensemble des sites	2 semaines
2	PKI / Easy-RSA	3 jours
3	VPN site-à-site (IPSec)	1 semaine
4	VPN accès distant (WireGuard)	1 semaine
5	IDS / IPS (Suricata)	1 semaine
6	DNS over TLS	2 jours
7	Analyse de trafic (ntopng)	1 semaine
8	Tests et recette technique (iPerf3)	2 semaines

5. Plan de Test et Critères de Validation

5.1 pfSense

- ☐ Les interfaces d'administration de chaque site sont accessibles.
- ☐ Les règles de filtrage bloquent effectivement le trafic non autorisé.
- ☐ Les services DHCP, NTP et DNS fonctionnent correctement sur chaque site.

5.2 VPN site-à-site (IPSec)

- ☐ La connectivité réseau est établie entre l'ensemble des sites.
- ☐ Le tunnel apparaît actif dans le tableau de bord de pfSense.
- ☐ Le chiffrement du trafic est vérifié par capture réseau.

5.3 VPN accès distant (WireGuard)

- ☐ Un télétravailleur peut établir une connexion depuis l'extérieur du réseau.
- ☐ L'utilisateur connecté accède aux ressources internes autorisées.
- ☐ La connexion reste stable et chiffrée dans la durée.

5.4 IDS / IPS (Suricata)

- ☐ Les alertes de détection remontent correctement dans l'interface pfSense.
- ☐ Un test d'intrusion simulé est détecté en mode IDS.
- ☐ Une attaque connue est effectivement bloquée une fois le mode IPS activé.

5.5 Analyse du trafic (ntopng)

- ☐ Le tableau de bord affiche le trafic réseau en temps réel.
- ☐ Le trafic shaping priorise correctement les applications métier.
- ☐ Des rapports de trafic peuvent être générés sur demande.

5.6 PKI

- ☐ Les certificats émis sont reconnus par l'ensemble des composants VPN.
- ☐ La procédure de révocation d'un certificat est fonctionnelle.

5.7 DNS over TLS

- ☐ Les requêtes DNS transitent de manière chiffrée, vérifiable par capture réseau.
- ☐ La résolution DNS reste fonctionnelle pour l'ensemble des postes du réseau.

Conclusion, Perspectives & Bibliographie

Responsable : Membre 5 — Gouvernance & Documentation

1. Synthèse de la proposition

Le projet OSSI démontre qu'une PME peut accéder à un niveau de sécurité d'ordre industriel sans avoir à subir de grande difficulté financière. En changeant le coût des licences par de l'expertise en ingénierie open source, la solution réduit le coût total de possession sur trois ans de plus de 45 000 € à environ 8 000 €, tout en maintenant un niveau de protection comparable.

Le projet mobilise de manière intégrée l'ensemble des concepts fondamentaux du management de projet requis par le module FG601 : définition rigoureuse du périmètre, analyse des parties prenantes, gouvernance par jalons, planification en Cycle en V, WBS et Gantt, registre des risques, indicateurs de pilotage, gestion d'un incident simulé et analyse critique. Chaque livrable du TD 01 est couvert et documenté.

2. Décision recommandée au Comité de Pilotage

L'équipe recommande au Comité de Pilotage la validation du lancement du projet OSSI, sous réserve des conditions suivantes :

- Attribution du budget de 6 875 € (dont 5 400 € de ressources humaines et 850 € de matériel reconditionné, avec une marge de sécurité de 625 €).
- Confirmation de la disponibilité des 5 membres de l'équipe sur les 8 séances du Mastercamp.
- Validation du périmètre MoSCoW : protection des fonctions Must Have (pfSense, IPSec, Suricata) en priorité absolue, report des fonctions de confort (IA Ollama) en cas de tension sur le chemin critique.
- Engagement de la PME utilisatrice sur la mise à disposition d'un administrateur IT référent pour la phase de transfert de propriété en séance 8.